

EXECUTIVE SECURITY ASSESSMENT REPORT

Target Environment

Forgotten Portal – DockerLabs Lab Environment

Classification	CONFIDENTIAL
Report Date	March 23, 2026
Prepared By	Valentina Ramírez
Organization	EAFIT University
Audience	Executive Leadership / Management
Overall Risk Rating	CRITICAL

This report is intended for executive and management audiences. Technical detail is provided in the companion Penetration Testing Technical Report.

Table of Contents

1. Executive Summary	3
Top 3 Critical Findings — Plain Language Summary	3
2. Business Risk Overview	4
2.1 What These Vulnerabilities Mean in Business Terms	4
2.2 Real-World Attack Scenarios for Top Findings	4
3. Financial Impact Analysis	6
3.1 IBM Cost of a Data Breach Report 2024 — Key Figures	6
3.2 Estimated Financial Exposure	6
3.3 Cost of Remediation vs. Cost of Breach	7
4. Risk Heat Map	8
5. Findings Summary	9
6. Prioritized Remediation Roadmap	11
7. ROI of Security Investment	12
8. Compliance Considerations	13
9. Conclusions and Next Steps	14
Recommended Immediate Actions (This Week)	14
Recommended Short-Term Actions (Next 30–90 Days)	14
Recommended Strategic Actions	14

1. Executive Summary

A structured security assessment was conducted on March 23, 2026 against the Forgotten Portal web application environment. The assessment evaluated the security posture of the internet-facing web application and the underlying server infrastructure using industry-standard penetration testing methodology (PTES).

The assessment resulted in complete, end-to-end compromise of the target system — from the first unauthenticated interaction with the website to full administrative (root) control of the server. The overall risk rating is CRITICAL. Seven security vulnerabilities were identified; three are rated Critical severity, meaning they are actively exploitable and require immediate remediation. No advanced techniques or specialized expertise were required to carry out the attack.

Top 3 Critical Findings — Plain Language Summary

#	Finding	What This Means in Practice
1	Unrestricted File Upload	Anyone on the internet could upload malicious code to the website, gaining the ability to run commands on the server without any login credentials. This was the primary entry point for the attack.
2	Shared Access Credential	All user accounts on the server shared a single login key. Obtaining the key from any one user granted access to every other user account, including administrators.
3	Passwordless Admin Access	One user account could become a full system administrator using a single command and without entering a password. This allowed the attacker to achieve complete server takeover.

2. Business Risk Overview

2.1 What These Vulnerabilities Mean in Business Terms

The vulnerabilities identified in this assessment represent complete failures in the foundational security controls of the assessed environment. When viewed collectively, they form an unbroken attack chain from public internet to full server ownership. In a production environment, this chain of compromise would expose an organization to the following business risks:

Business Risk	Description
Data Breach	Full read access to all server files, databases, and user data was achieved. Any customer, partner, or employee records stored on or accessible from the server would be exposed to an attacker.
Ransomware / Extortion	With root-level server control, an attacker could encrypt all data and demand payment for decryption keys, causing complete operational disruption until the ransom is paid or systems are rebuilt.
Service Disruption	An attacker with full administrative access could shut down, deface, or destroy the web application and any services it supports, disrupting operations for an indefinite period.
Regulatory Exposure	Data breaches involving personal or financial information may trigger mandatory notification requirements and potential fines under applicable data protection regulations (e.g., Colombia's Law 1581 on personal data protection).
Reputational Damage	Public disclosure of a breach or website defacement causes long-lasting damage to client trust and brand reputation, particularly in client-facing industries.
Lateral Movement to Connected Systems	Server compromise could serve as a launchpad to attack other internal systems, business applications, or partner networks connected to the same infrastructure.

2.2 Real-World Attack Scenarios for Top Findings

The following scenarios illustrate how the top three critical findings could be exploited in a real production environment, with no fictional elements — the attack techniques documented in this assessment are identical to those used by real threat actors and are publicly documented.

Scenario A — Ransomware Deployment via Web Shell (FINDING-02)

A threat actor identifies the file upload form using automated scanning tools (a process that takes minutes). They upload a web shell, gain server access, and within hours deploy ransomware across the environment — encrypting all server data and any connected file shares. The business loses access to its systems until a ransom is paid or systems are rebuilt.

from backup. According to the IBM Cost of a Data Breach 2024, the average cost of a ransomware attack is \$4.91M USD, not including reputational damage.

Scenario B — Silent Data Exfiltration via Credential Compromise (FINDINGS-04, 05, 06)

An attacker quietly extracts credentials from the server log file and uses them to access multiple user accounts over an extended period. Because all accounts share the same SSH key, lateral movement is effortless. The attacker exfiltrates customer data, financial records, or intellectual property over weeks without triggering any alerts. IBM 2024 data shows that breaches remaining undetected for over 200 days cost an average of \$5.18M — \$1.25M more than those detected within 200 days.

Scenario C — Full System Takeover and Backdoor Installation (FINDING-07)

Using a single command, an attacker escalates to root access. From this position, they install a persistent backdoor to maintain access even after patching, create hidden administrator accounts, exfiltrate all server data, and erase audit logs to obscure their presence. Recovery requires a complete system rebuild and a thorough investigation of potentially months of undiscovered activity.

3. Financial Impact Analysis

3.1 IBM Cost of a Data Breach Report 2024 — Key Figures

The following figures are sourced directly from the IBM Cost of a Data Breach Report 2024, the most comprehensive annual study of breach costs globally. These figures provide the financial context for the risk exposure identified in this assessment.

Metric (IBM 2024)	Value
Global average cost of a data breach	\$4.88 million USD
Average cost per compromised record	\$165 USD
Average time to identify and contain a breach	258 days
Average cost — breach detected in under 200 days	\$3.93 million USD
Average cost — breach detected in over 200 days	\$5.18 million USD
Financial savings from early detection	\$1.25 million USD
Percentage of breaches involving stolen credentials	16% of all breach events

3.2 Estimated Financial Exposure

Based on the vulnerabilities identified and the IBM 2024 benchmark data, the following table estimates the potential financial exposure for an organization operating a comparable production environment. Figures assume a medium-sized business with approximately 5,000 to 10,000 data records.

Exposure Scenario	Estimated Cost	Basis
Minimum (5,000 records exposed, breach detected early)	~\$825,000 USD	5,000 × \$165 per record (IBM 2024)
Moderate (10,000 records, breach detected within 200 days)	~\$3.93M USD	IBM 2024 average for early-detected breaches
Severe (10,000 records, breach detected after 200 days)	~\$5.18M USD	IBM 2024 average for late-detected breaches
Given the absence of detection controls in this environment, the	\$4.88M USD (global average)	IBM 2024 global average breach cost

late-detection scenario is the most probable.		
---	--	--

3.3 Cost of Remediation vs. Cost of Breach

The following comparison contrasts the estimated cost to remediate all seven findings against the potential cost of a breach. The cost of remediation is a one-time, bounded expense. The cost of a breach is ongoing, unpredictable, and includes indirect costs such as legal fees, regulatory fines, business disruption, and reputational damage.

Item	Estimated Cost	Notes
FINDING-01 – Remove HTML comments	\$300–\$500	30–60 minutes of developer time
FINDING-02 – Secure file upload validation	\$1,500–\$2,500	Development and testing effort
FINDING-03 – Disable directory listing	\$200–\$400	Server configuration change only
FINDING-04 – Audit and secure log files	\$2,500–\$4,000	Log review, sanitization, policy update
FINDING-05 – Regenerate all SSH keys	\$1,500–\$3,000	Key generation, deployment, documentation
FINDING-06 – Remove exposed passphrase	\$300–\$600	File removal and policy implementation
FINDING-07 – Fix sudo configuration	\$200–\$400	Configuration change, 30 minutes
TOTAL REMEDIATION COST	~\$6,500–\$11,400 USD	One-time investment
POTENTIAL BREACH COST (Late Detection)	~\$5.18 million USD	IBM 2024 benchmark — late-detected breach
RETURN ON REMEDIATION INVESTMENT	~454:1	Every \$1 spent on remediation avoids up to \$454 in potential breach costs

4. Risk Heat Map

The heat map below positions each finding according to its assessed Likelihood of exploitation (horizontal axis) and potential business Impact (vertical axis). The color of each cell reflects the resulting risk level. Findings located in red cells represent immediate business risk requiring urgent action.

Impact / Likelihood	1 Very Low	2 Low	3 Medium	4 High	5 Very High
5 – Critical	HIGH	HIGH	F07 CRITICAL	F05 CRITICAL	F02 CRITICAL
4 – High	MEDIUM	HIGH	HIGH	F04/F06 CRITICAL	CRITICAL
3 – Medium	LOW	MEDIUM	HIGH	HIGH	CRITICAL
2 – Low	LOW	LOW	MEDIUM	F01/F03 HIGH	HIGH
1 – Very Low	LOW	LOW	LOW	MEDIUM	MEDIUM

CRITICAL — Immediate Action	HIGH — Remediate in 30 Days	MEDIUM — Remediate in 90 Days	LOW — Next Cycle
---------------------------------------	---------------------------------------	---	-------------------------

5. Findings Summary

The following summary describes each finding in plain business language. Technical implementation details are available in the companion Technical Report.

ID	Severity	Title	Business Impact Summary
FINDING-01	MEDIUM	Sensitive Internal Information Left in Public Code	Internal usernames and hidden system paths were embedded in the public-facing website code and readable by anyone who viewed the page source in a browser. This information served as the initial roadmap for the attack.
FINDING-02	CRITICAL	Any File Can Be Uploaded to the Website — Including Malicious Code	The website's document upload feature accepted executable program files (.php) in addition to documents. An attacker who uploaded a malicious file gained the ability to execute any command on the server, as if sitting at the keyboard. This was the primary entry point for the attack.
FINDING-03	MEDIUM	Uploaded Files Are Listed Publicly	The folder where uploaded files are stored was publicly browsable — anyone with the URL could see exactly which files had been uploaded, including their names and timestamps. This confirmed the presence of the malicious file uploaded in FINDING-02.
FINDING-04	HIGH	An Employee's Password Was Stored in a Log File	A server log file contained the username and password of an internal user (alice) encoded in a trivially reversible format. Any attacker who gained entry to the server could decode and use these credentials to impersonate the user and access additional areas of the system.
FINDING-05	CRITICAL	All User Accounts Share the Same Login Credential (SSH Key)	A single digital key that grants remote server access was copied to every user account on the system. Normally, each user should have a unique key. Sharing one key means that obtaining it from any one user grants access to all users — completely eliminating account isolation.
FINDING-06	HIGH	A User's Password Was Written in a Document on the Server	An internal incident report stored on the server contained the passphrase for the shared login key written in plain text. Combined with the shared key vulnerability (FINDING-05), this allowed the attacker to authenticate as any user on the system.
FINDING-07	CRITICAL	One User Account Has Unrestricted Administrative Access Without a Password	User bob was configured to run a specific system utility (tar) as a full administrator without requiring any password. This utility can be used as a backdoor to gain complete administrator (root) control of the system. The attack is documented publicly and takes seconds to execute.

6. Prioritized Remediation Roadmap

Remediation is organized into three time horizons based on finding severity and business risk. Critical findings in the 0–30 day window represent active attack vectors and should be treated as emergency items. All findings can be addressed within standard operating budget; the total remediation cost is a fraction of the potential breach cost.

Timeline	Finding	Action Required	Effort	Est. Cost	Risk Reduction
0–30 Days	FINDI NG-02	Restrict file uploads to documents only; move uploads outside web root	Medium	\$1,500–\$2,500	Eliminates primary initial access vector
0–30 Days	FINDI NG-07	Remove passwordless admin access for user bob; audit all similar configurations	Very Low	\$200–\$400	Closes root escalation path — 30-minute fix
0–30 Days	FINDI NG-05	Generate unique login credentials per user; revoke all shared keys	Medium	\$1,500–\$3,000	Restores user account isolation
30–90 Days	FINDI NG-04	Audit all log files for credentials; implement secure credential storage policy	Medium	\$2,500–\$4,000	Removes lateral movement path via credential exposure
30–90 Days	FINDI NG-06	Remove the incident report containing the passphrase; establish secrets management policy	Very Low	\$300–\$600	Closes secondary credential exposure path
30–90 Days	FINDI NG-03	Disable public directory browsing on the web server	Very Low	\$200–\$400	Reduces attack surface and information exposure
90+ Days	FINDI NG-01	Remove internal notes from public website code; implement pre-deployment review process	Low	\$300–\$500	Removes reconnaissance advantage for attackers

7. ROI of Security Investment

The table below presents a direct comparison between the cost of remediating all identified vulnerabilities and the potential financial exposure of a data breach — based exclusively on IBM 2024 benchmark data. The return on investment for security remediation in this case is exceptional.

Security Investment	Potential Breach Cost Avoided
Total Remediation Cost \$6,500 – \$11,400 USD <i>One-time, bounded expenditure</i>	Potential Breach Cost (IBM 2024) \$4.88 million USD <i>Global average — ongoing, unpredictable</i>
Return on Security Investment (ROSI)	Approximately 454:1 — every \$1 invested avoids up to \$454 in breach costs

8. Compliance Considerations

The vulnerabilities identified in this assessment have direct implications for compliance with widely adopted security and data protection frameworks. While this engagement was conducted in a lab environment, equivalent vulnerabilities in a production context would likely constitute control failures under the following frameworks:

Framework	Relevant Control Area	Implication
ISO/IEC 27001:2022	Access Control (A.5.15), Secure Coding (A.8.28), Vulnerability Management (A.8.8)	Failure to restrict file uploads, shared credentials, and excessive sudo privileges constitute control failures under Annex A of ISO 27001.
NIST Cybersecurity Framework (CSF 2.0)	Protect (PR.AC, PR.DS), Detect (DE.CM)	The absence of file type validation, secure credential storage, and monitoring controls maps to deficiencies in the Protect and Detect functions.
Colombia Law 1581 / Decree 1377	Protection of personal data; security measures for data controllers	If personal data were stored or processed on the assessed environment, the vulnerabilities identified would represent inadequate technical safeguards under Colombian data protection law.
OWASP Top 10 (2021)	A01 Broken Access Control, A05 Security Misconfiguration, A02 Cryptographic Failures	FINDING-02 (file upload) maps directly to A05; FINDING-04 (Base64 credentials) maps to A02; sudo misconfiguration maps to A01.

Organizations subject to regulatory audit should treat the remediation of Critical and High findings as a compliance obligation, not only a security best practice.

9. Conclusions and Next Steps

This assessment confirms that the Forgotten Portal environment, if deployed in a production context, would represent an unacceptable security risk to any organization operating it. The attack chain documented in this report — from unauthenticated website access to full system administrator control — requires no specialized knowledge, no zero-day vulnerabilities, and no expensive tools. All exploited weaknesses are well-documented and have known, straightforward remediation steps.

The good news is that the remediation path is clear, affordable, and achievable within a short timeframe. The three Critical findings can be resolved within one to two weeks by a competent development or IT team. At approximately \$10,000 in total remediation cost against a potential \$4.88 million breach exposure, the investment case is unambiguous.

Recommended Immediate Actions (This Week)

- Restrict file upload functionality to documents only — remove .php from permitted file types (FINDING-02).
- Audit and remove all sudo NOPASSWD entries for utilities that can execute shell commands (FINDING-07).
- Begin SSH key rotation — generate unique keys for all user accounts and revoke the shared key (FINDING-05).

Recommended Short-Term Actions (Next 30–90 Days)

- Audit all log files and remove any stored credentials. Implement log sanitization policies (FINDING-04).
- Remove the incident report file containing the SSH passphrase and adopt a secrets management solution (FINDING-06).
- Disable directory listing on the web server and restrict HTTP access to the uploads folder (FINDING-03).
- Review and remove all HTML comments containing internal information from the production codebase (FINDING-01).

Recommended Strategic Actions

- Implement a Security Information and Event Management (SIEM) solution to provide continuous monitoring and alerting for anomalous activity.
- Establish a formal Vulnerability Management Program with regular penetration testing and patch management cycles.
- Evaluate alignment with ISO/IEC 27001 or NIST CSF as a structured security governance framework.
- Conduct security awareness training for development and IT staff, with emphasis on secure coding practices, credential management, and configuration hardening.

This report was prepared by Valentina Ramírez, as part of the Nodo EAFIT Cybersecurity Accelerator program. For questions regarding findings, remediation guidance, or re-assessment scheduling, please contact her directly.